



ACTIVIDAD 17

Evaluación de Vulnerabilidades con CVSS v3.1

CON V: Seguridad Informática

Servando López Contreras

Álvarez Aquino Enrique – 177071

Arellano Wratny Elisa Alejandra – 177339

López Alemán Emiliano – 182883

Portales Pérez Luis Gabriel – 174278

Rodríguez Rivera José Vicente – 179954

Evaluación de Vulnerabilidades con CVSS v3.1

1. Introducción

La seguridad de la información se ha convertido en un elemento fundamental para las organizaciones modernas debido al incremento constante de amenazas y vulnerabilidades presentes en los sistemas tecnológicos. En entornos corporativos, una vulnerabilidad puede comprometer la confidencialidad, integridad y disponibilidad de la información, generando riesgos operativos, financieros y reputacionales. Por esta razón, resulta indispensable contar con metodologías estandarizadas que permitan evaluar y priorizar adecuadamente los riesgos asociados a dichas vulnerabilidades.

El sistema Common Vulnerability Scoring System (CVSS) versión 3.1 es uno de los estándares más utilizados a nivel internacional para la evaluación de vulnerabilidades de seguridad informática. Este modelo proporciona un mecanismo estructurado para medir la severidad de una vulnerabilidad mediante métricas técnicas relacionadas con la facilidad de explotación, el nivel de privilegios requerido y el impacto potencial sobre los activos de información.

En la presente actividad se realiza el análisis de una vulnerabilidad detectada en un sistema web interno utilizando el modelo CVSS v3.1. A partir del escenario propuesto, se identifican las métricas base correspondientes, se construye el vector CVSS y se calcula la puntuación de riesgo mediante la calculadora oficial del estándar. Finalmente, se lleva a cabo una interpretación técnica de los resultados obtenidos con el propósito de comprender la relevancia de la vulnerabilidad y su impacto dentro de un contexto organizacional.

El desarrollo de este análisis permite fortalecer la comprensión de las métricas base del estándar CVSS, así como la capacidad de interpretar técnicamente los niveles de severidad y priorización del riesgo en escenarios reales de ciberseguridad.

2. Objetivos

2.1 Objetivo General

Aplicar el modelo CVSS v3.1 para evaluar la gravedad de vulnerabilidades reales, interpretando correctamente sus métricas base y justificando la priorización del riesgo en un contexto organizacional.

2.2 Objetivos Específicos

- Identificar y comprender las métricas base de CVSS v3.1.
- Construir correctamente un vector CVSS a partir de un escenario técnico.
- Calcular e interpretar la puntuación de riesgo utilizando la calculadora oficial.

3.Marco Teórico

3.1 ¿Qué es una vulnerabilidad?

Riesgo para CIA (Confidencialidad, Integridad, Disponibilidad)

Una vulnerabilidad es una debilidad o falla presente en un sistema, aplicación, red o dispositivo que puede ser aprovechada por un atacante para comprometer la seguridad de la información. Estas vulnerabilidades pueden originarse por errores de configuración, fallas de programación, software desactualizado o malas prácticas de seguridad.

El principal riesgo de una vulnerabilidad es que puede afectar los tres pilares fundamentales de la seguridad informática conocidos como la triada CIA:

- **Confidencialidad (Confidentiality):** Garantiza que la información solo sea accesible para usuarios autorizados. Una vulnerabilidad puede provocar filtración o robo de datos sensibles.
- **Integridad (Integrity):** Asegura que la información no sea modificada de manera no autorizada. Una vulnerabilidad podría permitir alteraciones indebidas en archivos o bases de datos.
- **Disponibilidad (Availability):** Garantiza que los sistemas y servicios estén disponibles cuando se necesiten. Una vulnerabilidad puede ocasionar interrupciones o caídas del sistema.

Por esta razón, identificar y evaluar vulnerabilidades es una actividad esencial dentro de la ciberseguridad organizacional.

3.2 ¿Qué es CVSS v3.1?

El Common Vulnerability Scoring System (CVSS) versión 3.1 es un estándar internacional desarrollado por la organización FIRST para evaluar la severidad de vulnerabilidades de seguridad informática. Su principal objetivo es proporcionar un método estandarizado que permita medir el nivel de riesgo de una vulnerabilidad mediante una puntuación numérica.

CVSS ayuda a las organizaciones a priorizar la atención de vulnerabilidades de acuerdo con su impacto potencial y facilidad de explotación. El sistema utiliza distintas métricas

relacionadas con aspectos técnicos de la vulnerabilidad, como el nivel de acceso requerido, la complejidad del ataque y el impacto sobre la confidencialidad, integridad y disponibilidad.

La puntuación final de CVSS se expresa en una escala de 0.0 a 10.0, donde valores más altos representan vulnerabilidades más críticas.

3.3. Estructura de CVSS

CVSS v3.1 se encuentra dividido en tres grupos principales de métricas que permiten evaluar distintos aspectos de una vulnerabilidad.

3.3.1 Métricas Base

Las métricas base representan las características fundamentales de una vulnerabilidad que no cambian con el tiempo ni dependen del entorno donde se encuentre el sistema afectado. Estas métricas analizan la facilidad de explotación y el impacto técnico generado sobre la confidencialidad, integridad y disponibilidad.

Las métricas base son las más importantes dentro del cálculo CVSS debido a que determinan la puntuación principal de severidad.

3.3.2 Métricas Temporales

Las métricas temporales consideran factores que pueden cambiar con el tiempo, como la existencia de exploits públicos, herramientas de ataque disponibles o actualizaciones de seguridad liberadas por el fabricante.

Estas métricas permiten ajustar la puntuación base dependiendo de la situación actual de la vulnerabilidad.

3.3.3 Métricas Ambientales

Las métricas ambientales permiten adaptar la evaluación CVSS al contexto específico de una organización. Consideran aspectos como la importancia de los sistemas afectados y los requisitos de seguridad particulares del entorno.

Gracias a estas métricas, una organización puede determinar si una vulnerabilidad representa un riesgo mayor o menor según sus propios activos y operaciones.

3.4 Métricas Base CVSS v3.1

Métrica	Nombre	Significado
AV	Attack Vector	Define desde dónde puede explotarse la vulnerabilidad, por ejemplo mediante red, acceso local o físico.
AC	Attack Complexity	Indica el nivel de complejidad necesario para ejecutar el ataque exitosamente.
PR	Privileges Required	Representa el nivel de privilegios que necesita el atacante antes de explotar la vulnerabilidad.
UI	User Interaction	Determina si se requiere interacción de un usuario legítimo para que el ataque funcione.
S	Scope	Indica si la vulnerabilidad afecta únicamente al sistema vulnerable o puede impactar otros componentes.
C	Confidentiality	Mide el impacto sobre la confidencialidad de la información.
I	Integrity	Evalúa el impacto sobre la integridad de los datos o sistemas.
A	Availability	Mide el impacto sobre la disponibilidad de los servicios o recursos afectados.

3.5 Clasificación de Severidad

La clasificación de severidad en CVSS v3.1 permite interpretar el nivel de riesgo que representa una vulnerabilidad de acuerdo con la puntuación obtenida. Esta clasificación ayuda a las organizaciones a priorizar la atención y remediación de vulnerabilidades según el impacto potencial que podrían generar sobre los sistemas y la información.

Rango de puntuación	Nivel de Severidad	Descripción
0.1 - 3.9	Baja	La vulnerabilidad presenta un impacto limitado y representa un riesgo reducido para la organización. Generalmente no compromete de manera significativa la operación de los sistemas.
4.0 - 6.9	Media	La vulnerabilidad puede afectar parcialmente la seguridad de los activos de información y requiere atención para evitar posibles incidentes de seguridad.
7.0 - 8.9	Alta	La vulnerabilidad representa un riesgo considerable debido a que puede ser explotada con relativa facilidad y generar impactos importantes sobre la organización.
9.0 - 10.0	Crítica	La vulnerabilidad tiene un impacto extremadamente grave y puede comprometer de manera severa la confidencialidad, integridad y disponibilidad de los sistemas. Requiere atención inmediata.

4. Caso Práctico

4.1 Escenario

Una organización detectó una vulnerabilidad dentro de un sistema web interno utilizado para la gestión de información corporativa. El análisis preliminar determinó que dicha vulnerabilidad puede ser explotada remotamente a través de la red, sin necesidad de acceso físico al sistema comprometido. Asimismo, se identificó que la explotación presenta una baja complejidad técnica, por lo que no requiere condiciones especiales o avanzadas

para ser ejecutada. Sin embargo, el atacante necesita contar con privilegios elevados dentro del sistema para poder aprovechar la vulnerabilidad. Adicionalmente, la explotación no requiere interacción por parte del usuario y no provoca cambios en el alcance de seguridad del sistema afectado. Respecto al impacto potencial, se determinó que las afectaciones sobre la confidencialidad, integridad y disponibilidad de la información son de nivel bajo, debido a que la vulnerabilidad únicamente compromete parcialmente los recursos del entorno evaluado sin generar una afectación crítica sobre la operación general de la organización.

4.2 Identificación de métricas

Característica del escenario	Métrica CVSS	Valor
Explotable por red	AV	N
Baja complejidad	AC	L
Privilegios elevados	PR	H
Sin interacción	UI	N
Alcance sin cambios	S	U
Impacto bajo en confidencialidad	C	L
Impacto bajo en integridad	I	L
Impacto bajo en disponibilidad	A	L

4.3 Construcción de vector CVSS

Con base en las métricas identificadas en el escenario planteado, se construyó el siguiente vector CVSS v3.1:

CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

Donde:

- **AV:N (Attack Vector: Network)**: La vulnerabilidad puede explotarse remotamente mediante la red.
- **AC:L (Attack Complexity: Low)**: La explotación no requiere condiciones complejas.

- **PR:H (Privileges Required: High):** Se necesitan privilegios elevados para ejecutar el ataque.
- **UI:N (User Interaction: None):** No se requiere interacción del usuario.
- **S:U (Scope: Unchanged):** El alcance de seguridad no cambia.
- **C:L (Confidentiality: Low):** Existe bajo impacto sobre la confidencialidad.
- **I:L (Integrity: Low):** Existe bajo impacto sobre la integridad.
- **A:L (Availability: Low):** Existe bajo impacto sobre la disponibilidad.

A partir de este vector es posible calcular la puntuación base utilizando la calculadora oficial de CVSS v3.1 y determinar el nivel de severidad correspondiente.

5. Interpretación

A pesar de requerir privilegios elevados (PR:H), esta vulnerabilidad sigue siendo relevante porque representa un riesgo que podría ser explotado por un atacante interno malintencionado o por un agente externo que ya haya logrado comprometer una cuenta administrativa mediante otros métodos. El tipo de atacante que podría explotarla es un insider (empleado o colaborador con acceso) o un atacante avanzado que busquen escalar privilegios tras una intrusión inicial. Que el impacto sea bajo (L) en las tres dimensiones de la tríada CIA (Confidencialidad, Integridad y Disponibilidad) significa que la explotación exitosa sólo permitiría un acceso parcial a la información, modificaciones limitadas en los datos o interrupciones menores en el servicio, sin llegar a comprometer la totalidad del sistema o la continuidad crítica del negocio.

6. Cálculo de Puntuación

6.1 Calculadora oficial



Common Vulnerability Scoring System Version 3.1 Calculator

Hover over metric group names, metric names and metric values for a summary of the information in the official CVSS v3.1 Specification Document. The Specification is available in the list of links on the left, along with a User Guide providing additional scoring guidance, an Examples document of scored vulnerabilities, and notes on using this calculator (including its design and an XML representation for CVSS v3.1).

Base Score

4.7
(Medium)

Attack Vector (AV)

Network (N)

Adjacent (A)

Local (L)

Physical (P)

Attack Complexity (AC)

Low (L)

High (H)

Privileges Required (PR)

None (N)

Low (L)

High (H)

User Interaction (UI)

None (N)

Required (R)

Scope (S)

Unchanged (U)

Changed (C)

Confidentiality (C)

None (N)

Low (L)

High (H)

Integrity (I)

None (N)

Low (L)

High (H)

Availability (A)

None (N)

Low (L)

High (H)

6.2 Resultado obtenido

Métrica	Resultado
Vector Base	CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L
Impact Subscore (ISS)	3.4
Exploitability Subscore (ESS)	1.2
Final Base Score	4.7

6.3 Puntuación Base

6.3.1 ¿Cuál es la puntuación base?

La puntuación base calculada para este vector es de **4.7**.

6.3.2 ¿En qué categoría cae?

De acuerdo con la escala oficial, una puntuación de 4.7 cae en la categoría **Media** (ya que se encuentra dentro del rango de 4.0 - 6.9).

Rango	Categoría
0.1 - 3.9	Baja
4.0 - 6.9	Media
7.0 - 8.9	Alta

7. Conclusión

El análisis realizado mediante el estándar CVSS v3.1 permitió identificar y evaluar la severidad de una vulnerabilidad presente en un sistema web interno, determinando una puntuación base de 4.7, correspondiente a un nivel de severidad media. Aunque la vulnerabilidad requiere privilegios elevados para ser explotada, factores como la posibilidad de explotación remota, la baja complejidad del ataque y la ausencia de interacción del usuario mantienen un nivel de riesgo relevante dentro del entorno organizacional.

La aplicación del modelo CVSS facilitó la traducción de características técnicas de la vulnerabilidad en una evaluación cuantitativa y estandarizada, permitiendo comprender el impacto potencial sobre la confidencialidad, integridad y disponibilidad de la información. Asimismo, el uso de la calculadora oficial permitió validar la construcción correcta del vector CVSS y priorizar el riesgo conforme a criterios internacionales de ciberseguridad.

Este ejercicio demuestra la importancia de utilizar metodologías formales de evaluación de vulnerabilidades para apoyar la toma de decisiones en seguridad informática, priorizar acciones de mitigación y fortalecer la postura de seguridad de las organizaciones frente a amenazas internas y externas.

Referencias

- [FIRST.org](https://www.first.org/cvss/v3.1/specification-document). (2019). *Common Vulnerability Scoring System version 3.1: Specification document*. FIRST. <https://www.first.org/cvss/v3.1/specification-document> ([first.org](https://www.first.org))
- FIRST. (n.d.). *CVSS v3.1 calculator*. Forum of Incident Response and Security Teams (FIRST). <https://www.first.org/cvss/calculator/3.1>
- National Institute of Standards and Technology. (n.d.). *National Vulnerability Database (NVD): Vulnerability metrics (CVSS)*. <https://nvd.nist.gov/vuln-metrics/cvss>